Industrial Security (Bachelor)

Solution Sheet – Section 10

Incident Response and Recovery

How to use this sheet: the solutions are sample answers, not the only correct ones. Each solution box ends with a **Rubric** hint listing the points that must appear for full marks. If the student's answer covers the rubric with different but defensible choices, mark it as correct.

Solution

Exercise 10.1 – Historian ransomware tabletop. *T+0–30 min, Detection & Analysis:* operator confirms HMI still controls process (safety unaffected); shift supervisor opens incident ticket; on-call OT security pages incident commander. *T+30–90 min, Containment:* IC isolates Historian VLAN at L3 firewall but leaves SCADA-HMI path intact so operators keep visibility; PCAP and ransom note hashed and preserved; backup admin pulls last-night immutable backup off the shelf and does *not* restore yet. *T+90–180 min, Escalation:* plant manager declares Severity 1; legal and PR briefed; national CSIRT receives NIS2 Art. 23(4)(a) early warning placeholder; cyber-insurance hotline opened. *T+180–240 min, Decision:* plant manager (not security) decides whether to continue production blind on trends or step down to a safe state; comms sends internal stand-up note; 24-hour early-warning text drafted for sign-off before the legal deadline. **Rubric:** (1) safety check first, (2) named decision owner per step, (3) preservation before remediation, (4) NIS2 24-hour clock acknowledged, (5) plant manager owns the production decision.

Solution

Exercise 10.2 – Forensic scope. *PLC (M580 / S7-1500): can* pull running project via vendor tool, diagnostic buffer, firmware version, CPU mode; *cannot* pull a forensic memory image (no documented dump interface, vendor often refuses), no per-byte disk image; *compensating*: signed baseline comparison, upstream PCAP of S7/Modbus writes, engineering audit trail. *HMI:* can image disk and RAM (Windows host), event logs, USB history; cannot trust the HMI clock alone; compensating: SIEM correlation, AD logon events. *Engineering WS:* can image disk, RAM, TIA / RSLogix audit trail, project-file timestamps, USB history, browser history; cannot recover deleted ladder-logic versions if project-file history is off; compensating: vendor cloud sync, git history, PLC-side "last download" record. *Network:* full PCAP at the iDMZ and L2 access switch (if SPAN/TAP exists), NetFlow, IDS alerts, firewall syslog, DHCP/DNS logs; cannot get what was never captured; compensating: historical NetFlow, neighbour-switch ARP/MAC tables. **Rubric:** each row has all three columns; mention the PLC memory-dump gap (NIST SP 800-86 "volatile data" is largely infeasible on controllers); mention chain of custody.

Solution

Exercise 10.3 – RACI for "Shut down Unit 2". Sample assignment: *Responsible* – SCADA / DCS engineer (executes the controlled shutdown); *Accountable* – plant manager (owns production risk and the safety case); *Consulted* – security operations, HSE officer, legal; *Informed* – PR / communications. Security is not accountable because the cost of a wrong shutdown (lost batch, restart hazards, flare events) typically dwarfs the cyber risk, and only the plant manager has the statutory authority for an operating-permit-relevant decision. HSE is consulted (not accountable) because their role is to veto on safety grounds, not to own the production call. **Rubric:** exactly one Accountable; Accountable is the plant manager; HSE has a veto path; PR is Informed, not Consulted, in the decision moment.

Solution

Exercise 10.4 – Recovery validation of a re-flashed M580. (1) Firmware hash matches the vendor-published value (tool: vendor checksum utility; pass: byte-identical). (2) Project upload from the PLC equals the signed baseline project (tool: Unity Pro / Control Expert compare; pass: zero diff). (3) Diagnostic buffer is clean and time-synced to the plant NTP source (tool: vendor diag; pass: no unexplained entries since boot). (4) Network behaviour matches baseline – only expected peers, expected ports (tool: Zeek / Wireshark; pass: no new flows for 60 minutes idle). (5) Loop test with process simulator or on a bypassed loop confirms IO mapping and setpoints unchanged (tool: control engineer + isolated test rig; pass: outputs within tolerance). (6) 72-hour heightened-monitoring window with elevated SIEM rules on the controller's VLAN (tool: SIEM; pass: zero high-severity alerts before sign-off). **Rubric:** integrity check before behavioural check; project compared to *signed* baseline, not to "what we had yesterday"; explicit monitoring window after restart; plant manager (not security) signs the production-ready statement.

Solution

Exercise 10.5 – NIS2 early-warning sample text. *"This is an early warning under Art. 23(4)(a) of Directive (EU) 2022/2555. On 2026-05-12 at 22:15 CEST, [Utility] detected a confirmed compromise of a SCADA jump host serving its drinking-water control network. The incident is suspected to be caused by a malicious act; investigation is ongoing and no attribution is asserted at this time. Based on current information, cross-border impact is not expected, and drinking-water supply to customers is not affected. A full incident notification under Art. 23(4)(b) will follow within 72 hours."* **Rubric:** explicitly labelled as Art. 23(4)(a) early warning; states suspected malicious cause without attribution; cross-border statement present; commits to the 72-hour follow-up; 3–5 sentences; no speculation.

Solution

Exercise 10.6 – RTO / RPO assignment.

- **Historian** – RTO 24 h, RPO 1 h. Trend-gap tolerable; reporting continuity required.
- **MES** – RTO 8 h, RPO 4 h. Order tracking drives throughput billing.
- **SCADA HMI** – RTO 1 h, RPO 0. Operators lose visibility of the live process.
- **SIS** – RTO 0, RPO 0. Plant must trip rather than run without SIS.
- **Billing IT** – RTO 48 h, RPO 24 h. Customers tolerate one-day delay.
- **Document mgmt** – RTO 72 h, RPO 24 h. Change-mgmt only, not live ops.

Rubric: SIS has RTO/RPO of zero (plant trips, no degraded mode); HMI RTO is the tightest live-ops system; billing and document management are the loosest; every row carries a consequence anchor (safety / regulatory / financial / reputational).

Solution

Exercise 10.7 – Blameless vs. blameful opener. *Blameless:* "On 2026-04-18 at 09:42, a phishing email reached a control-room workstation and was opened. The click triggered a download that our endpoint controls did not block, and within 14 minutes the payload had reached the Historian. This post-mortem focuses on the system conditions that allowed a hostile message to reach a control-network host, the detection controls that missed the lateral move, and the response steps that worked. Our goal is to learn, not to assign blame: anyone in that seat could have clicked, and the system must tolerate that." *Blameful:* "On 2026-04-18, operator J. Schmidt clicked a phishing email despite annual training, causing the Historian outage. This document records the failure of the operator to follow policy and recommends disciplinary action." *Contrast:* the blameless version names the system gaps that need fixing and keeps operators willing to self-report next time; the blameful version drives reporting underground and leaves the email-gateway and segmentation gaps untouched, so the same class of incident will recur. **Rubric:** blameless opener names systems not people; blameful opener names the individual; contrast paragraph identifies the reporting-chill effect.

Solution

Exercise 10.8 – Tabletop design for pre-positioning. *Injects:* T+0 "EDR alert: persistent C2 beacon from ENG-WS-04"; T+15 "DNS logs show beacon active for 47 days"; T+30 "audit trail: TIA Portal opened project file PROD_REACTOR_3 yesterday"; T+60 "threat-intel: beacon TLS fingerprint matches reported state actor". *Discussion moments:* (1) Do we re-image now (and tip the adversary) or watch (and accept risk)? (2) Do we file an NIS2 Art. 23 early warning when there is no impact yet but malicious cause is likely? (3) Do we bring in the national CSIRT or handle internally? *Success criteria:* (a) team distinguishes "observe" from "act" deliberately, with named owner; (b) chain-of-custody plan for the WS image is named before any action; (c) NIS2 timing acknowledged and a draft early warning produced; (d) plant-manager decision on Unit 3 continued operation is taken on evidence, not feeling; (e) one concrete preparation gap is captured for the lessons-learned register. **Rubric:** realistic timeline (not all in one minute); at least one "observe vs. act" dilemma; explicit regulator question; named scoring criteria.

Solution

Exercise 10.9 – "Pull the cable" counter-examples. *Scenario A (SIS):* a workstation that programs a Triconex / HIMA SIS is suspected of compromise during a live batch. Pulling its network cable strands the SIS in its current configuration with no engineering visibility, and any subsequent process upset cannot be diagnosed or overridden. *Alternative:* freeze the workstation's user session, snapshot volatile memory and disk while still connected, isolate at the SIS-zone firewall after the batch reaches a safe hold point, and only then take the host offline. *Scenario B (Operator visibility):* the HMI server is suspected of compromise mid-shift. Yanking the network blinds the operator to alarms during a process transient; the resulting manual mishandling can be worse than the cyber incident itself. *Alternative:* bring up the warm-spare HMI on a clean VLAN, fail operators over, then quarantine the suspect HMI for forensics. **Rubric:** at least one SIS / safety-loop example; alternative is concrete (not just "be careful"); alternative preserves operator visibility and forensic evidence.

Solution

Exercise 10.10 – Lessons-learned feedback artefacts. (1) **Detection-rule updates** (owner: SOC lead; lives in SIEM / IDS rule repo; trigger: rule merged and tagged with incident ID). (2) **Updated network diagram / asset inventory** (owner: OT architect; lives in CMDB; trigger: diagram version bumped and approved by change board). (3) **Playbook revision** for the affected scenario class (owner: IR lead; lives in IR repo / runbook tool; trigger: new version published and team-read-receipted). (4) **Tabletop scenario** distilled from the real incident (owner: exercise coordinator; lives in the exercise library; trigger: scenario scheduled into the next quarter's tabletop). (5) **Backup / recovery procedure update** (owner: backup admin; lives in BCM runbook; trigger: dry-run restore performed and signed off by plant manager). **Rubric:** each artefact has owner / location / completion trigger; at least one feeds detection, one feeds rehearsal, one feeds recovery; "the post-mortem report" is not counted.